Phishing and social engineering



Sorena Golbarg

Student ID: 2520728

Table of Contents

1. Introduction *3*

2. Phishing and its different forms *4*

1. Smishing 5

2. Vishing 6

3. Business Email Compromise (BEC) 7

3. Psychological techniques *8*

1. Urgency 8

2. Fear 8

3. Scarcity / Fear of Missing Out 9

4. Indicators of phishing *10*

5. What should someone do if they suspect or click phishing? *11*

6. Conclusion *13*

7. Recourses *14*

1. Introduction

Phishing is a form of fraud in which criminals use text messages, emails, other communication methods, and especially fraudulent phone calls to deceive victims.

Phishing is a form of social engineering in which attackers impersonate trusted individuals or organisations to deceive victims into revealing sensitive information or carrying out unsafe actions.

In this report, I will examine different types of phishing, the psychological techniques used by attackers, common signs of phishing, and the actions that should be taken when dealing with a suspected phishing attack.

2. Phishing and its different forms

Phishing

Phishing is a type of social engineering attack in which criminals impersonate a trusted organisation or company and ask victims to disclose sensitive information or data, or to visit a malicious website or application.

Spear Phishing

Unlike general phishing attacks, spear phishing is highly targeted. Attackers first select a specific target, often someone working for a reputable or successful company, research that individual, and then send a personalised message specifically designed for them.

Example of general phishing:

Your Disney+ account has been suspended. Click here.

Example of spear phishing:

Hi Alex, I need you to check the new finance report.

1. Smishing

Smishing is phishing conducted through SMS or other text messages. Attackers commonly include malicious links or phone numbers and attempt to persuade victims to provide personal or financial information.

For example:

Your parcel could not be delivered. Pay £3.50 to reschedule delivery.

2. Vishing

In this type of phishing attack, the attacker uses a phone call and pretends to represent a government organisation, such as the police. They may then ask the victim to provide personal information, such as their National Insurance number.

Example:

“I am calling from the Metropolitan Police. Someone has committed an offence using your National Insurance number. Please provide your National Insurance number so that we can verify your identity.”

3. Business Email Compromise (BEC)

Business Email Compromise usually targets organisations. Attackers send emails while impersonating a colleague, manager, executive, or trusted business contact.

Compared with many other forms of phishing, BEC is often more targeted and commonly focuses on persuading the victim to make a large financial payment or transfer funds to a fraudulent account.

Example:

“Please transfer £10,000 to the new bank account of this supplier.”

3. Psychological techniques

Authority

This is one of the techniques used in social engineering because victims are more likely to follow instructions from a company manager, a government organisation, or another person or organisation with authority.

1. Urgency

Attackers often create artificial urgency by claiming that immediate action is required.

This reduces the time for the victim to critically evaluate the messages and may encourage faster decision-making.

Example:

Your account will be suspended in 50 minutes.

2. Fear

Fear can cause emotional decision makings

Messages may threaten the victim, financial loss or disciplinary action to pressure into following instructions.

For Example:

suspicious activity has been detected. Your bank account will be locked from you.

3. Scarcity / Fear of Missing Out

Example:

Only 4 places remaining. Claim your reward now or lose them.

phishing should not be understood as a technical attack. Its effectiveness depends on manipulating human psychological responses such as trust, fear and obedience to authority.

4. Indicators of phishing

The NCSC has provided guidance on several characteristics that can help users identify phishing attempts at an early stage. These include suspicious or incorrect email addresses, unknown links, unexpected attachments, unusual requests for personal information, spelling and grammatical mistakes, messages that create urgency or threats, low-quality logos or unusual designs, and generic greetings.

The sender's email address should be checked carefully because attackers may use an address that differs from the legitimate one by only a single letter or number.

Example:

Legitimate: support@paypal.com
Fake: support@paypa1.com

However, users should not rely only on these signs. A skilled phisher may create a highly professional message that closely resembles a genuine email, making it difficult for the victim to recognise that it is fraudulent.

5. What should someone do if they suspect or click phishing?

If a message appears suspicious, you should not click on any links or open any attached files. Instead, you should contact the organisation directly using its official phone number and ask about the message. You should also avoid using links provided in the suspicious message and manually visit the organisation's official website to check your account.

What if you have already clicked the link?

If you entered your password, you should change it immediately.

If you entered your banking information, you should contact your bank as soon as possible.

If you installed a suspicious application or file, you should immediately perform a security or antivirus scan on your device.

Individual and organisational response

The response to phishing should consider both individuals and organisations. At an organisational level, phishing should be addressed through multiple layers of security, and organisations should not rely entirely on employees to identify phishing attempts.

Organisations can use measures such as:

- Email filtering
- Spam protection
- Multi-factor authentication (MFA)
- SPF, DKIM and DMARC
- Security awareness training
- Incident reporting systems
- Incident response plans

Employee awareness is important, but it should not be the organisation's only method of defence against phishing attacks. Technical security controls and clear incident-response procedures should also be used to reduce the risk of successful attacks.

6. Conclusion

In conclusion, phishing is a social-engineering threat that can occur through email, SMS, voice communication and highly targeted business attacks. Its effectiveness is partly explained by psychological techniques including authority, urgency, fear and scarcity. Although suspicious addresses, links, attachments and unusual requests can help identify phishing, increasingly sophisticated attacks may contain few obvious warning signs. Consequently, both individual vigilance and organisational controls are required.

7. Recourses

Federal Bureau of Investigation. (n.d.) Business Email Compromise. [Online]. [Accessed 30 September 2026].

Federal Bureau of Investigation. (n.d.) Spoofing and Phishing. [Online]. [Accessed 30 September 2026].

Federal Trade Commission. (n.d.) Glossary of Scams and Legal Terms. [Online]. [Accessed 30 September 2026].

National Cyber Security Centre. (2018) Phishing attacks: defending your organisation. [Online]. [Accessed 30 September 2026].

National Cyber Security Centre. (2021a) Phishing scams: how to spot and report them. [Online]. [Accessed 30 September 2026].

National Cyber Security Centre. (2021b) Phishing scams: what to do if you have shared sensitive information. [Online]. [Accessed 30 September 2026].

National Cyber Security Centre. (2026) Small organisations guide to cyber security: spotting cyber attacks. [Online]. [Accessed 30 September 2026].

National Institute of Standards and Technology. (n.d.) Phishing. [Online]. [Accessed 30 September 2026].

Stylianou, I., Bountakas, P., Zarras, A. and Xenakis, C. (2025) 'Suspicious minds: Psychological techniques correlated with online phishing attacks', Computers in Human Behaviour Reports, 19, 100694.

Williams, E.J., Hinds, J. and Joinson, A.N. (2018) ‘Exploring susceptibility to phishing in the workplace’, International Journal of Human-Computer Studies, 120, pp. 1–13.